HIPAA in Plain Language: Does It Apply to Me?

A Guide for Counselors · Professional Tip · Brian Campbell, Ph.D.

Take a breath. If HIPAA has ever felt overwhelming, you are not alone. The rules read like a tax code, but the core ideas are simple: know whether the law covers you, protect what clients tell you, put a few basic papers in place, and know what to do if something goes wrong. This tip walks through each step in plain language.

Disclaimer. Dr. Campbell is not an attorney. This is general information, not legal advice. Laws and rules change, and your state law and licensing board may ask more of you than HIPAA does. Check them, and consult an attorney when you need help.

1. THE QUICK TEST: ARE YOU A "COVERED ENTITY"?

HIPAA does not apply to every counselor. It applies to a health care provider only if the provider sends health information electronically as part of certain standard insurance transactions. HHS calls these providers "covered entities." Ask yourself:

- **Electronic insurance business.** Do you file insurance claims electronically, check a client's insurance eligibility or benefits online, request prior authorizations, or receive electronic payment and remittance information from a health plan?
- **Through a billing service.** If a billing service or clearinghouse does any of this for you, it counts as you doing it. CMS says a provider who uses another company to send covered transactions on its behalf is treated as sending them.

If you answered yes to either, you are a covered entity and HIPAA applies to you. Once you are covered, the rules protect all of your clients' identifiable health information, whether it is on paper, on a computer, or spoken aloud, not just your insurance clients. If you are unsure, the free CMS Covered Entity Decision Tool (see Sources) walks you through a few yes-or-no questions.

What if I am cash-pay only?

A practice that never sends any of these standard electronic transactions is usually not a HIPAA covered entity. Handing a client a receipt or superbill that the client files on their own is not, by itself, you sending an electronic transaction. But being outside HIPAA does not mean you are free of privacy rules:

- Your state's confidentiality and privilege laws, your licensing board's rules, and your profession's ethics code (ACA, APA, NASW, AAMFT, and so on) still apply, and they often ask for nearly the same things.
- Some state laws are stricter than HIPAA. When a state law protects privacy more, the stricter law generally wins.
- If you take insurance in the future, even for one client, you become covered.

Many cash-pay counselors choose to follow HIPAA anyway as good practice. It gives clients a familiar standard and makes the switch easy if you ever start billing insurance.

2. STUDENTS, INTERNS, AND SUPERVISEES

- **You are part of the workforce.** HIPAA defines a practice's "workforce" to include employees, volunteers, and trainees whose work is under the practice's direct control, paid or not. A student or intern is not a separate covered entity. You follow the HIPAA policies of the agency or practice where you train.
- **Get trained.** A covered practice must train every workforce member on its privacy policies, including trainees. Ask for that training before you see clients.

- **Supervisors carry responsibility.** The site and supervisor are responsible for making sure trainees follow the rules. Supervisors should know what devices and apps their supervisees use for client work.
- **Protect case material.** HIPAA allows a practice to use client information for its own supervised training programs. When you take case material outside the practice, such as to a university class, remove anything that could identify the client (names, addresses, dates, phone numbers, photos, and similar details) or get the client's written permission.

3. THE MUST-HAVES IF YOU ARE COVERED

HIPAA is built to scale. A solo practice does not need a hospital's binder. The Security Rule expressly lets you weigh your size, resources, and costs when choosing safeguards. Here is the short list:

- **Notice of Privacy Practices (NPP).** Give it to each client by the first session, make a good-faith effort to get a signed acknowledgment, post it in your office, and post it on your website if you have one. As of February 16, 2026, the NPP must also include information about substance use disorder records. HHS offers free model notices.
- **A Privacy Official and a Security Official.** In a solo practice, that can be you. Write it down.
- **A risk analysis.** Look honestly at where client information lives (laptop, phone, cloud, file cabinet) and what could go wrong, then fix the biggest risks. HHS and ONC offer a free Security Risk Assessment Tool for small practices. Review it when things change.
- **Everyday safeguards.** Strong passwords and screen locks, encrypted devices, up-to-date software, locked file cabinets, and care with who can overhear or see screens.
- **Business Associate Agreements (BAAs).** Any outside company that creates, receives, stores, or transmits client information for you is a “business associate.” That includes electronic records systems, billing services, secure email, telehealth platforms, cloud storage, and AI tools. You need a signed BAA with each one before you put client information there. HHS says a cloud company is a business associate even if it stores only encrypted data it cannot read.
- **Clients' right to their records.** Clients may see and get copies of their records. Respond within 30 days (one 30-day extension is allowed with notice). You may charge only a reasonable, cost-based fee for labor, supplies, and postage. For electronic copies of electronic records, a flat fee of no more than $6.50 is one simple option.
- **Minimum necessary.** Share only what is needed for the purpose, such as with an insurer. This limit does not apply when you share with another provider for treatment or with the client.
- **Breach plan.** If client information is lost or seen by the wrong person, assess the risk. If it counts as a breach, notify affected clients without unreasonable delay and no later than 60 days after you discover it. Breaches affecting fewer than 500 people may be reported to HHS once a year, within 60 days after the end of the calendar year. Properly encrypted data that is lost generally does not require notice.
- **Training.** Train yourself and anyone who works with you, and keep a record of it.
- **Keep your HIPAA paperwork for 6 years.** Policies, your NPP, risk analysis, training records, and BAAs must be kept for six years from when they were created or last in effect, whichever is later. This is separate from how long you keep client records, which is set by state law and your board.

4. PSYCHOTHERAPY NOTES GET EXTRA PROTECTION

HIPAA treats “psychotherapy notes” specially. These are a mental health professional's notes recording or analyzing what was said in a session, kept separate from the rest of the client's record. They do not include start and stop times, diagnosis, treatment plan, symptoms, progress, test results, or medication. Those belong in the regular record.

- You generally need the client's specific written authorization to share psychotherapy notes, even with an insurer. Limited exceptions include your own use in treatment, the practice's supervised training programs, and defending yourself in a legal action brought by the client.

- HIPAA's right of access does not include psychotherapy notes, so you are not required by HIPAA to give clients a copy. You may choose to, and some state laws give clients broader access. Check yours.
- The protection only works if the notes are truly kept separate. Notes mixed into the main record are treated as part of the regular record.

5. TELEHEALTH, EMAIL, AND TEXTING

- **Allowed, with care.** HIPAA allows video sessions, email, and texting with clients when you use reasonable safeguards. For telehealth, use a platform that will sign a BAA. The COVID-era leniency for everyday video apps ended on May 11, 2023, with a grace period that closed on August 9, 2023.
- **Simple habits.** Double-check addresses and numbers, and keep the details in messages to what is needed.
- **Client choice.** Clients may ask you to communicate a certain way, such as regular email. If a client asks for copies of their records by unencrypted email, HHS says to briefly warn them of the risk and confirm they still want it that way. If they say yes, you must honor it, and you are not responsible for what happens to it in transit. If a client emails you first, you can generally assume email is acceptable to them unless they say otherwise. Note their choice in the record.

6. AI TOOLS AND CLIENT INFORMATION

AI programs that draft notes, summarize sessions, or help with treatment planning are new, but the HIPAA rule for them is the same as for any cloud service:

- If an AI tool stores or processes identifiable client information for you, the company behind it is a business associate. Use it with client information only if the company signs a BAA and the protections described in your risk analysis are in place.
- Without a BAA, use only fictional or properly de-identified information. HHS says a service that handles only de-identified information is not a business associate.
- There is no such thing as being “HIPAA certified” or “HIPAA approved.” HHS does not endorse or certify any technology. A vendor's “HIPAA-compliant” label is a claim, not a government stamp, and it does not replace a signed BAA and your own judgment.

About Clinical Companion. Clinical Companion is being set up to work under signed business associate agreements with the services it relies on. Until those agreements are in place, use it only with fictional or de-identified practice cases.

7. TWO RECENT RULE CHANGES, BRIEFLY

- **Reproductive health rule.** A 2024 rule added protections for reproductive health information. A federal court in Texas struck down most of it on June 18, 2025. The part that survived requires your Notice of Privacy Practices to include information about substance use disorder records (see Section 3).
- **Substance use disorder records (Part 2).** Separate federal rules (42 CFR Part 2) protect records from federally assisted substance use disorder treatment programs. If you run or work in such a program, or receive its records, extra rules apply. Most private counseling practices are not Part 2 programs.
- **Still pending.** HHS has proposed changes to the Security Rule and the Privacy Rule, but as of this writing they are proposals, not law. Check HHS.gov for updates.

SOURCES

- HHS – Covered Entities and Business Associates: https://www.hhs.gov/hipaa/for-professionals/covered-entities/index.html
- CMS – Are You a Covered Entity?: https://www.cms.gov/priorities/key-initiatives/burden-reduction/administrative-simplification/hipaa/covered-entities

- CMS – Covered Entity Decision Tool (PDF): https://www.cms.gov/regulations-and-guidance/administrative-simplification/hipaa-aca/downloads/coveredentitieschart20160617.pdf
- eCFR – 45 CFR 160.103 (definitions: covered entity, workforce, PHI): https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-160/subpart-A/section-160.103
- eCFR – 45 CFR 160.203 (stricter state laws): https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-160/subpart-B/section-160.203
- eCFR – 45 CFR Part 164 (Security, Breach, and Privacy Rules): https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164
- HHS – Model Notices of Privacy Practices: https://www.hhs.gov/hipaa/for-professionals/privacy/guidance/model-notices-privacy-practices/index.html
- HHS – Guidance on HIPAA and Cloud Computing: https://www.hhs.gov/hipaa/for-professionals/special-topics/health-information-technology/cloud-computing/index.html
- HHS – Individuals' Right of Access (incl. fees): https://www.hhs.gov/hipaa/for-professionals/privacy/guidance/access/index.html
- HHS FAQ – Unencrypted email at the client's request: https://www.hhs.gov/hipaa/for-professionals/faq/2060/do-individuals-have-the-right-under-hipaa-to-have/index.html
- HHS FAQ – Emailing patients: https://www.hhs.gov/hipaa/for-professionals/faq/570/does-hipaa-permit-health-care-providers-to-use-email-to-discuss-health-issues-with-patients/index.html
- HHS – Breach Notification Rule: https://www.hhs.gov/hipaa/for-professionals/breach-notification/index.html
- HHS – HIPAA and Telehealth: https://www.hhs.gov/hipaa/for-professionals/special-topics/telehealth/index.html
- Federal Register – End of COVID-19 enforcement discretion (Apr. 13, 2023): https://www.federalregister.gov/documents/2023/04/13/2023-07824/notice-of-expiration-of-certain-notifications-of-enforcement-discretion-issued-in-response-to-the
- HHS – Mental and Behavioral Health (incl. Part 2): https://www.hhs.gov/hipaa/for-professionals/special-topics/mental-health/index.html
- HHS – Reproductive Health Rule fact sheet (court decision note): https://www.hhs.gov/hipaa/for-professionals/special-topics/reproductive-health/final-rule-fact-sheet/index.html
- HealthIT.gov – Security Risk Assessment Tool: https://www.healthit.gov/topic/privacy-security-and-hipaa/security-risk-assessment-tool

Sources checked November 3, 2026. This is general information, not legal advice. Check your state law and licensing board, and consult an attorney for your situation.

Brian Campbell, Ph.D.